

The Duplicitious Nature of AWS Identity and Access Management (IAM)

Jason Kao, Fog Security

fwd:cloudsec 2025

Agenda

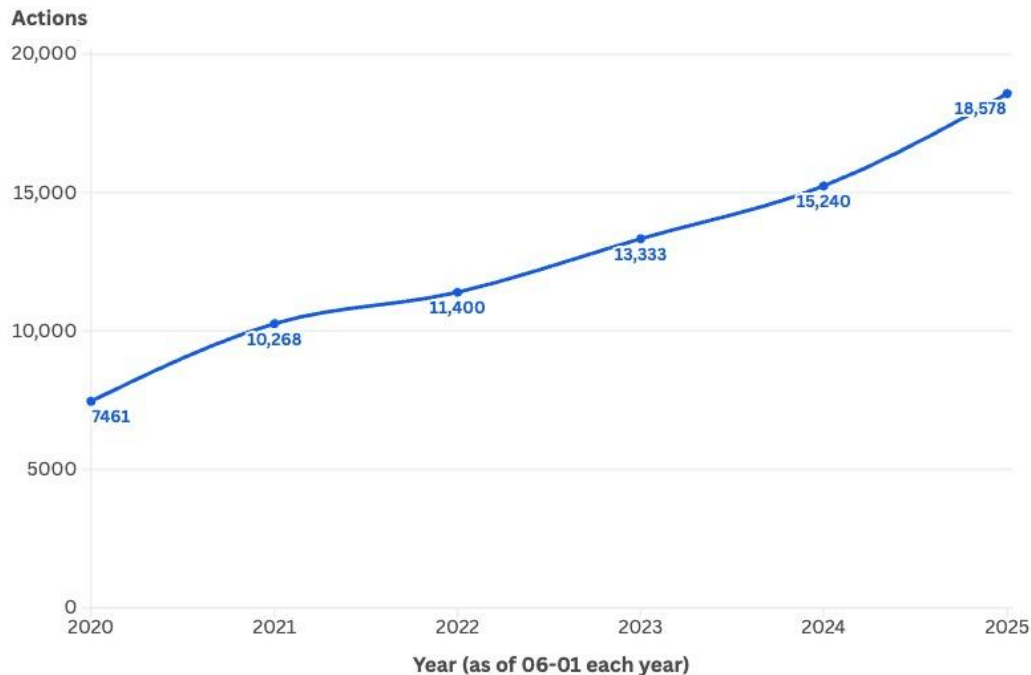
- AWS IAM and Shared Responsibility Model
- Duplicate IAM Permissions
- AWS Provided Resolutions
- Complexity
- Best Practices and Management



AWS IAM: All of the Permissions

AWS has over 18,000 permissions across 200+ services.

AWS IAM Actions



Raw data sourced from iam-dataset by Ian McKay

Note: AWS IAM was launched in 2011, iam-dataset only has data from 2020.

AWS IAM: What It Looks Like

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "Hellofwdcloudsec2025",
      "Effect": "Allow",
      "Action": [
        "sqs:AddPermission",
        "lambda:AddPermission",
        "lambda:List*",
        "iam:Get*"
      ],
      "Resource": "*"
    }
  ]
}
```

```
policy = {
  <version_block?>
  <id_block?>
  <statement_block>
}

<version_block> = "Version" : ("2008-10-17" | "2012-10-17")

<id_block> = "Id" : <policy_id_string>

<statement_block> = "Statement" : [ <statement>, <statement>, ... ]

<statement> = {
  <sid_block?>,
  <principal_block?>,
  <effect_block>,
  <action_block>,
  <resource_block>,
  <condition_block?>
}

<sid_block> = "Sid" : <sid_string>

<effect_block> = "Effect" : ("Allow" | "Deny")

<principal_block> = ("Principal" | "NotPrincipal") : ("*" | <principal_map>)

<principal_map> = { <principal_map_entry>, <principal_map_entry>, ... }

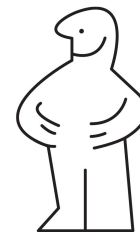
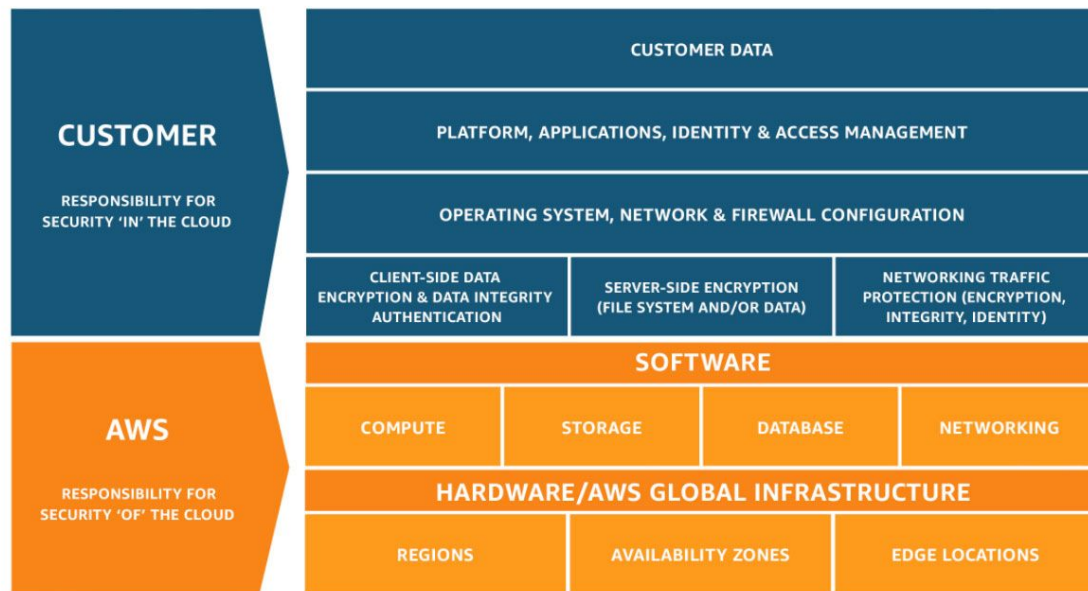
<principal_map_entry> = ("AWS" | "Federated" | "Service" | "CanonicalUser") :
  [ <principal_id_string>, <principal_id_string>, ... ]

<action_block> = ("Action" | "NotAction") :
  ("*" | [<action_string>, <action_string>, ...])

<resource_block> = ("Resource" | "NotResource") :
  ("*" | [<resource_string>, <resource_string>, ...])

<condition_block> = "Condition" : { <condition_map> }
<condition_map> = {
  <condition_type_string> : { <condition_key_string> : <condition_value_list> },
  <condition_type_string> : { <condition_key_string> : <condition_value_list> }, ...
}
<condition_value_list> = [<condition_value>, <condition_value>, ...]
<condition_value> = ("string" | "number" | "Boolean")
```

Shared Responsibility Model



The Meaning of Duplicate Permissions

duplicate 1 of 3 adjective

du·pli·cate 'dü-pli-kət also 'dyü-

[Synonyms of duplicate >](#)

1 : consisting of or existing in two corresponding or identical parts or examples

duplicate invoices

2 : being the same as another

duplicate copies

duplicity noun

du·plic·i·ty dü-'pli-sə-tē also dyü-

plural **duplicities**

[Synonyms of duplicity >](#)

1 : contradictory doubleness of thought, speech, or action

the simplicity and openness of their lives brought out for him the *duplicity* that lay at the bottom of ours

— Mary Austin

especially : the **belying** of one's true intentions by deceptive words or action

2 : the quality or state of being double or **twofold**

3 **law** : the technically incorrect use of two or more distinct items (such as claims, charges, or defenses) in a single legal action

The (AI) Meaning of Duplicate Permissions

What are duplicate AWS IAM permissions?



Perplexity



Sources · 8



Steps



docs.aws.amazon.com

Change permissions for an IAM user - AWS...



docs.aws.amazon.com

Policies and permissions in AWS Identity and Access...



Blog by Max Ivanov

How to make a copy of AWS IAM role - Blog by Max...



Stack Overflow

Need to make an identical copy of AWS IAM role...

Duplicate AWS IAM Permissions Explained

Duplicate AWS IAM permissions refer to situations where a user, group, or role is granted the same or overlapping permissions through multiple policies or policy attachments within AWS Identity and Access Management (IAM). This can occur in several ways:

- A user may be assigned to multiple groups, each granting the same permissions.
- Multiple policies (managed or inline) attached to a user, group, or role may contain identical or overlapping permission statements.
- Permissions may be granted both directly and indirectly (e.g., a user has a policy attached directly and also receives the same permissions via group membership) ¹ ².

How Duplicate Permissions Arise

- **Multiple Policy Attachments:** AWS IAM allows attaching multiple policies to a single identity (user, group, or role). If different policies grant the same actions on the same resources, the

The (AI) Meaning of Duplicate Permissions

ChatGPT ▾

What are duplicate AWS IAM permissions?

Duplicate AWS IAM permissions refer to **redundant or overlapping permissions** granted to a user, group, or role in AWS Identity and Access Management (IAM). These can arise when the same action is allowed multiple times through different policies or policy statements. Although AWS evaluates permissions based on the effective permissions (i.e., the union of all permissions applied), duplicates can lead to:

- **Policy bloat** (unnecessarily large and complex policies)
- **Maintenance challenges**
- **Increased risk of misconfiguration**

Examples of Duplicate IAM Permissions

1. **Same permission in multiple policies**



Show Me The Meaning

2 or more AWS IAM Permissions that correspond to the same outcome or effect.

In some cases, managing one permission does not have any effect on the other permission. Thus, denying 1 permission does not affect the usage of the other permission.

What We're Not Really Covering: Part 1

IAM: Attaching Policies (Granting Permissions) to an IAM User

- IAM User Inline Policy:
 - iam:PutUserPolicy
- Attach Managed Policy directly to User
 - iam:AttachUserPolicy
- IAM Group Inline Policy:
 - iam:PutGroupPolicy
- Attach Policy directly to Group
 - iam:AttachGroupPolicy

What We're Not Really Covering: Part 2

Reading Data in DynamoDB:

- `DynamoDB:GetItem`
- `DynamoDB:Query`
- `DynamoDB:Scan`
- `DynamoDB:PutItem`
- `DynamoDB:UpdateItem`
- `DynamoDB:DeleteItem`

Additional:

- `DynamoDB:BatchGetItem`
- `DynamoDB: PartiQLSelect`

Thanks to Aidan Steele for initial research & Daniel Grzelak for bringing this to my attention.

What We're Not Really Covering: Part 3

Deleting Data in S3:

- s3:DeleteObject
- s3:DeleteObjectVersioning
- s3:PutLifecycleConfiguration

Duplicate Permissions

Duplicate Permissions: AWS Account Information

Service: AWS Account

Effect: Modify contact information for an account.

Permissions:

- **aws-portal:ModifyAccount**
- **account:PutContactInformation**

Duplicate Permissions: AWS Account Information

Service: AWS Account

Effect: Modify alternate information for an account (such as security, billing, operations)

Permissions:

- **aws-portal:ModifyAccount**
- **account:PutAlternateContactInformation**

Duplicate Permissions: AWS Identity Center (SSO)

Service: AWS Identity Center

Effect: Add Permissions (Policies) to a Permission Set

Permissions:

- **sso:PutPermissionsPolicy**
- **sso:PutInlinePolicyToPermissionSet**

Duplicate Permissions: AWS Identity Center (SSO)

Service: AWS Identity Center

Effect: Manage User's Group Membership

Permissions:

- **identitystore:CreateGroupMembership**
- **sso-directory:AddMemberToGroup**

Duplicate Permissions: Raw Email Sending

Service: Amazon Simple Email Service (SES)

Effect: Send Raw Email (raw, MIME-formatted email message)

Permissions:

- **ses:SendRawEmail (v1)**
- **ses:SendEmail(v2)**

Duplicate Permissions: Templated Email Sending

Service: Amazon Simple Email Service (SES)

Effect: Send Templated Email

Permissions:

- **ses:SendTemplatedEmail (v1)**
- **ses:SendEmail(v2)**

Duplicate Permissions: Account Email Sending

Service: Amazon Simple Email Service (SES)

Effect: Enable or disable email sending across the entire Amazon SES account in a region.

Permissions:

- **ses:UpdateAccountSendingEnabled (v1)**
- **ses:PutAccountSendingAttributes (v2)**

Duplicate Permissions: Manage Email Identity Access

Service: Amazon Simple Email Service (SES)

Effect: Manage Access to a SES Identity (domain and email addresses)

Permissions:

- **ses:PutIdentityPolicy (v1)**
- **ses:CreateEmailIdentityPolicy (v2) and ses:UpdateEmailIdentityPolicy (v2)**

Duplicate Permissions: Manage Email Identity Access

Service: Amazon Simple Email Service (SES)

Effect: Manage Access to a SES Identity (domain and email addresses)

Permissions:

- **ses:DeleteIdentityPolicy (v1)**
- **ses:DeleteEmailIdentityPolicy (v2)**

Duplicate Permissions: Messaging Queues

Service: AWS Simple Queue Service (SQS)

Effect: Manage Access to the SQS Queue via resource-based policy.

Permissions:

- **sqs:SetQueueAttributes**
- **sqs:AddPermission**

Duplicate Permissions: Encryption Management

Service: AWS Key Management Service (KMS)

Effect: Remove access to a KMS Key by deleting a key grant

Permissions:

- **kms:RetireGrant**
- **kms:RevokeGrant**

Duplicate Permissions: Services Covered

- Amazon Simple Email Service (SES)
- Amazon Identity Center, formerly known as AWS Single Sign-On
- Amazon Simple Queue Service (SQS)
- AWS Key Management Service (KMS)
- AWS Account

Duplicate Permissions: Trends

- **Service Age**
- **Types of Permissions**

Service	Date
Amazon SES	Early 2011
Amazon SQS	2004
AWS SSO	2017
Identity Center	2022

Duplicate Permissions: Differences

Difference: Managing Queue Permissions

sqs:AddPermission

```
aws sqs add-permission \  
--queue-url https://sqs.us-east-1.amazonaws.com/123412341234/Queue \  
--label additionalperm \  
--aws-account-ids 432143214321 \  
--actions SendMessage
```

sqs:SetQueueAttributes

Request Parameters

For information about the parameters that are common to all actions, see [Common Parameters](#).

Attribute

Attribute.N.Name (key)

Attribute.N.Value (value)

A map of attributes to set.

The following lists the names, descriptions, and values of the special request parameters that the `SetQueueAttributes` action uses:

- `DelaySeconds` – The length of time, in seconds, for which the delivery of all messages in the queue is delayed. Valid values: An integer from 0 to 900 (15 minutes). Default: 0.
- `MaximumMessageSize` – The limit of how many bytes a message can contain before Amazon SQS rejects it. Valid values: An integer from 1,024 bytes (1 KiB) up to 262,144 bytes (256 KiB). Default: 262,144 (256 KiB).
- `MessageRetentionPeriod` – The length of time, in seconds, for which Amazon SQS retains a message. Valid values: An integer representing seconds, from 60 (1 minute) to 1,209,600 (14 days). Default: 345,600 (4 days). When you change a queue's attributes, the change can take up to 60 seconds for most of the attributes to propagate throughout the Amazon SQS system. Changes made to the `MessageRetentionPeriod` attribute can take up to 15 minutes and will impact existing messages in the queue potentially causing them to be expired and deleted if the `MessageRetentionPeriod` is reduced below the age of existing messages.
- `Policy` – The queue's policy. A valid AWS policy. For more information about policy structure, see [Overview of AWS IAM Policies](#) in the *AWS Identity and Access Management User Guide*.
- `ReceiveMessageWaitTimeSeconds` – The length of time, in seconds, for which a `ReceiveMessage` action waits for a message to arrive. Valid values: An integer from 0 to 20 (seconds). Default: 0.
- `VisibilityTimeout` – The visibility timeout for the queue, in seconds. Valid values: An integer from 0 to 43,200 (12 hours). Default: 30. For more information about the visibility timeout, see [Visibility Timeout](#) in the *Amazon SQS Developer Guide*.

Difference: Account Information

aws-portal:ModifyAccount

Console Only

▼ Contact Information

Please note that updating your contact information on this page will not update the information displayed on your PDF Invoices. If you wish to update the billing address information associated with your Invoice, please edit it through the Payment Methods page, located [here](#).

Full Name:*	Me Not Me
Address:*	Hello it's me
City:*	
State:*	
Postal Code:*	
Country:*	United States
Phone Number:*	8675309
Company Name:	
Website URL:	

* Denotes required field

Update

Cancel

account:PutContactInformation

API/CLI Only

aws account put-contact-information

--contact-information \

```
{"AddressLine1": "123 Sesame Street", "City":  
"Raleigh", "CompanyName": "Sesame",  
"CountryCode": "US", "DistrictOrCounty":  
"District", "FullName": "Me Not Me",  
"PhoneNumber": "+18675309", "PostalCode":  
"27606", "StateOrRegion": "NC", "WebsiteUrl":  
"https://www.websiteurl.com"}
```

Difference: SSO Identity Center

identitystore:CreateGroupMembership

API/CLI Only

```
aws identitystore create-group-membership --identity-store-id d-1234123abc  
--group-id 12341234-1234-1234-123412341234 --member-id  
UserId=12341234-4321-4321-4321-432143214321
```

sso-directory:AddMemberToGroup

Console Only

Errors occurred while adding user "test-json2"

▼ User "test-json2" couldn't be added to group "test"

 jason.cow is not authorized to perform: sso-directory:AddMemberToGroup because no identity-based policy allows the sso-directory:AddMemberToGroup action

Difference: Simple Email Service

While there is SES (original) and SES v2, the service prefix remains the same for both SES and SES v2.

The screenshot displays the AWS IAM console interface for configuring permissions for two services: SES v2 and SES.

SES v2 Section:

- Service:** SES v2
- Actions:** Specify the actions allowed in SES v2. A search bar labeled "Filter actions" is present. Below it, the option **All SES v2 actions (ses:*)** is selected and highlighted with a red box. Under "Access level", the following options are listed: List, Read, Tagging, Write, and Permissions management.
- Resources:** Choose actions before applying resources.
- Request conditions:** Choose actions before specifying conditions.
- Buttons:** Clone, Remove, Switch to deny permissions, Expand all, Collapse all.

SES Section:

- Service:** SES
- Actions:** Specify the actions allowed in SES. A search bar labeled "Filter actions" is present. Below it, the option **All SES actions (ses:*)** is selected and highlighted with a red box. Under "Access level", the following options are listed: List, Read, Write, and Permissions management.
- Buttons:** Clone, Remove, Switch to deny permissions, Expand all, Collapse all.

Difference: Deleting a KMS Key Grant

kms:RetireGrant

- Permissions via KMS Key Grant

```
aws kms create-grant \
--key-id arn:aws:kms:us-east-1:123412341234
--grantee-principal arn:aws:iam::123412341234:
--operations DescribeKey Decrypt GenerateDataKey
--retiring-principal arn:aws:iam::123412341234:

aws kms create-grant \
--key-id arn:aws:kms:us-east-1:123412341234
--grantee-principal arn:aws:iam::123412341234:
--operations RetireGrant DescribeKey Decrypt
```

kms:RevokeGrant

- Permissions via Key Policy

```
{
  "Sid": "RevokeGrantKeyAdmin",
  "Effect": "Allow",
  "Principal": {
    "AWS": "arn:aws:iam::123412341234:root"
  },
  "Action": "kms:RevokeGrant",
  "Resource": "*"
}
```


Duplicate Permissions: Differences

Key Differences:

- How to Grant Permission
 - KMS Key Grant vs KMS Key Policy
- API Versions
 - SES v1 and SES v2.
 - Identity Center and SSO
- Console vs API
 - Account
 - Identity Center

How does AWS help us manage duplicate permissions?

AWS Provided Resolutions: Retirement of Permissions

AWS Account Modification

- July 2023, AWS retired aws-portal prefixed permissions.

AWS Provided Resolutions: Retirement of Permissions

Note

The following AWS Identity and Access Management (IAM) actions have reached the end of standard support on July 2023:

- `aws-portal` namespace
- `purchase-orders:ViewPurchaseOrders`
- `purchase-orders:ModifyPurchaseOrders`

If you're using AWS Organizations, you can use the [bulk policy migrator scripts](#) to update polices from your payer account. You can also use the [old to granular action mapping reference](#) to verify the IAM actions that need to be added.

For more information, see the [Changes to AWS Billing, AWS Cost Management, and Account Consoles Permission](#)  blog.

If you have an AWS account, or are a part of an AWS Organizations created on or after March 6, 2023, 11:00 AM (PDT), the fine-grained actions are already in effect in your organization.

AWS Provided Resolutions: IAM Condition Keys

Condition Key: ses:ApiVersion

Condition keys	Description	Type
ses:ApiVersion	Filters actions based on the SES API version	String

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": [
        "ses:*"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "ses:ApiVersion": "2"
        }
      }
    }
  ]
}
```

AWS Provided Resolutions: Documentation Only

AddPermission

PDF

Adds a permission to a queue for a specific [principal](#). This allows sharing access to the queue.

When you create a queue, you have full control access rights for the queue. Only you, the owner of the queue, can grant or deny permissions to the queue. For more information about these permissions, see [Allow Developers to Write Messages to a Shared Queue](#) in the *Amazon SQS Developer Guide*.

Note

- `AddPermission` generates a policy for you. You can use `SetQueueAttributes` to upload your policy. For more information, see [Using Custom Policies with the Amazon SQS Access Policy Language](#) in the *Amazon SQS Developer Guide*.
- An Amazon SQS policy can have a maximum of seven actions per statement.
- To remove the ability to change queue permissions, you must deny permission to the `AddPermission`, `RemovePermission`, and `SetQueueAttributes` actions in your IAM policy.
- Amazon SQS `AddPermission` does not support adding a non-account principal.

SetQueueAttributes

PDF

Sets the value of one or more queue attributes. When you change a queue's attributes, the change can take up to 60 seconds for most of the attributes to propagate throughout the Amazon SQS system. Changes made to the `MessageRetentionPeriod` attribute can take up to 15 minutes and will impact existing messages in the queue potentially causing them to be expired and deleted if the `MessageRetentionPeriod` is reduced below the age of existing messages.

Note

- In the future, new attributes might be added. If you write code that calls this action, we recommend that you structure your code so that it can handle new attributes gracefully.
- Cross-account permissions don't apply to this action. For more information, see [Grant cross-account permissions to a role and a username](#) in the *Amazon SQS Developer Guide*.
- To remove the ability to change queue permissions, you must deny permission to the `AddPermission`, `RemovePermission`, and `SetQueueAttributes` actions in your IAM policy.

AWS Provided Resolutions: Documentation Only

RetireGrant

[PDF](#)

Deletes a grant. Typically, you retire a grant when you no longer need its permissions. To identify the grant to retire, use a [grant token](#), or both the grant ID and a key identifier (key ID or key ARN) of the KMS key. The [CreateGrant](#) operation returns both values.

This operation can be called by the *retiring principal* for a grant, by the *grantee principal* if the grant allows the `RetireGrant` operation, and by the AWS account in which the grant is created. It can also be called by principals to whom permission for retiring a grant is delegated. For details, see [Retiring and revoking grants](#) in the *AWS Key Management Service Developer Guide*.

For detailed information about grants, including grant terminology, see [Grants in AWS KMS](#) in the *AWS Key Management Service Developer Guide*. For examples of working with grants in several programming languages, see [Programming grants](#).

Cross-account use: Yes. You can retire a grant on a KMS key in a different AWS account.

Required permissions: Permission to retire a grant is determined primarily by the grant. For details, see [Retiring and revoking grants](#) in the *AWS Key Management Service Developer Guide*.

Related operations:

- [CreateGrant](#)
- [ListGrants](#)
- [ListRetirableGrants](#)
- [RevokeGrant](#)

RevokeGrant

[PDF](#)

Deletes the specified grant. You revoke a grant to terminate the permissions that the grant allows. For more information, see [Retiring and revoking grants](#) in the *AWS Key Management Service Developer Guide*.

When you create, retire, or revoke a grant, there might be a brief delay, usually less than five minutes, until the grant is available throughout AWS KMS. This state is known as *eventual consistency*. For details, see [Eventual consistency](#) in the *AWS Key Management Service Developer Guide*.

For detailed information about grants, including grant terminology, see [Grants in AWS KMS](#) in the *AWS Key Management Service Developer Guide*. For examples of working with grants in several programming languages, see [Programming grants](#).

Cross-account use: Yes. To perform this operation on a KMS key in a different AWS account, specify the key ARN in the value of the `KeyId` parameter.

Required permissions: [kms:RevokeGrant](#) (key policy).

Related operations:

- [CreateGrant](#)
- [ListGrants](#)
- [ListRetirableGrants](#)
- [RetireGrant](#)

AWS Provided Resolutions: Documentation Only

IAM Identity Center console and API authorization

[PDF](#) | [RSS](#)

Existing IAM Identity Center console APIs support dual authorization. If you have existing IAM Identity Center instances that were created prior to October 15th 2020, you can use the following table to determine which API operations now map to newer API operations that were released after that date.

IAM Identity Center instances created before October 15th 2020 honor both old and new API actions as long as there is no explicit deny on any of the actions. Instances created after October 15th 2020 use the [newer API actions](#) for authorization in the IAM Identity Center console.

Operation name	API actions used before October 15th, 2020	API actions used after October 15th, 2020
DeletePermissionSet	DeletePermissionSet	DeletePermissionSet
DescribePermissionsPolicies	DescribePermissionsPolicies	ListManagedPoliciesInPermissionSet
DetachManagedPolicy	DeletePermissionsPolicy	DetachManagedPolicyFromPermissionSet
DisassociateProfile	DisassociateProfile	DeleteAccountAssignment
GetApplicationInstanceForAWSAccount	GetApplicationInstance	ListAccountAssignments
GetAWSAccountProfileStatus	GetProfile	ListPermissionSetsProvisionedToAccount
GetPermissionSet	GetPermissionSet	DescribePermissionSet
GetPermissionsPolicy	GetPermissionsPolicy	GetInlinePolicyForPermissionSet
ListAccountsWithProvisionedPermissionSet	ListApplicationInstances GetApplicationInstance	ListAccountsForProvisionedPermissionSet
ListAWSAccountProfiles	ListProfiles GetProfile	ListPermissionSetsProvisionedToAccount
ListPermissionSets	ListPermissionSets	ListPermissionSets
ListProfileAssociations	ListProfileAssociations	ListAccountAssignments
ProvisionApplicationInstanceForAWSAccount	GetApplicationInstance CreateApplicationInstance	CreateAccountAssignment
ProvisionApplicationProfileForAWSAccountInstance	GetProfile CreateProfile UpdateProfile	CreateAccountAssignment
ProvisionSAMLProvider	GetTrust CreateTrust UpdateTrust	CreateAccountAssignment
PutPermissionsPolicy	PutPermissionsPolicy	PutInlinePolicyToPermissionSet

Managing Duplicate Permissions: Summary

AWS Provided:

- Condition Keys
- Documentation
- Console vs API
- Retirement of Permissions

Duplicate Permissions: Complexity

Complexity: Logging & Monitoring

[CloudTrail](#) > Event history

Event history (2) [Info](#)

Event history shows you the last 90 days of management events.

Lookup attributes

Read-only ▼

🔍 false ✕

2023-04-08 (14:27:00) > 2023-04-08 (14:40:00) 🗓️ < 1 > ⚙️

☐	Event name	Event time	Event source	Resource type
☐	SetQueueAttributes	April 08, 2023, 14:37:14 (UTC-04:00)	sqs.amazonaws.com	AWS::SQS::Queue
☐	AddPermission	April 08, 2023, 14:27:50 (UTC-04:00)	sqs.amazonaws.com	AWS::SQS::Queue

Complexity: Logging & Monitoring

[CloudTrail](#) > Event history

Event history (2) [Info](#)

Event history shows you the last 90 days of management events.

Lookup attributes

Read-only ▼

Q false X

30m 1h 3h 12h Clear

Custom (5m)

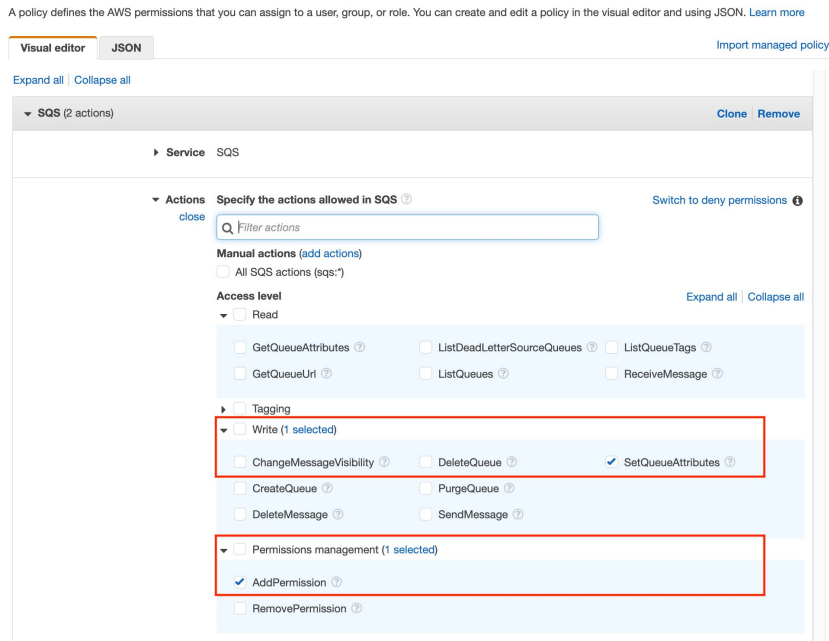
< 1 >

☐	Event name	Event time	Event source	Resource type
☐	SetContactAddress	April 08, 2023, 15:08:10 (UTC-04:00)	billingconsole.amazonaws.com	-
☐	PutContactInformation	April 08, 2023, 15:07:20 (UTC-04:00)	account.amazonaws.com	-

Complexity: Inconsistent Understanding

Permissions are classified inconsistently.

- SQS:AddPermission is classified as **Permissions Management**.
- sqs:SetQueueAttributes is classified as **Write**.



Complexity: Inconsistent Understanding

- The plot thickens (6/30/25). SQS Queue Policy Classification

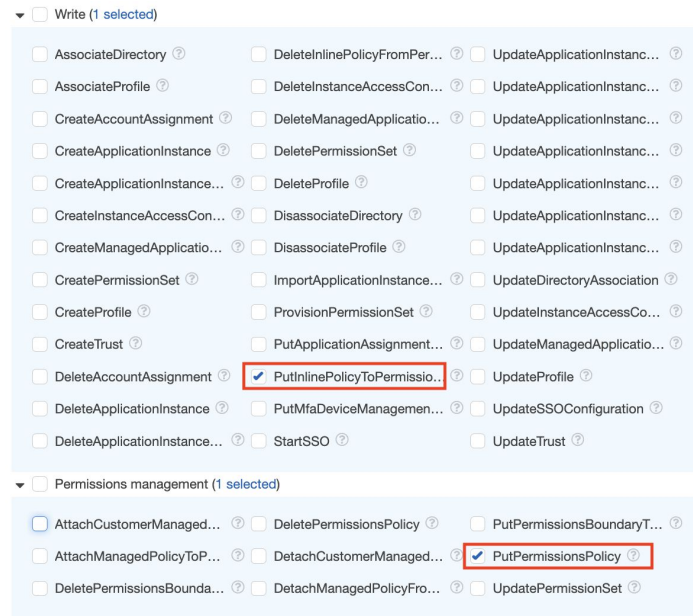
```
"Name" : "SetQueueAttributes",  
"Annotations" : {  
  "Properties" : {  
    "IsList" : false,  
    "IsPermissionManagement" : true,  
    "IsTaggingOnly" : false,  
    "IsWrite" : true  
  }  
},
```

SetQueueAttributes	Grants permission to set the value of one or more queue attributes	Write	queue*
--------------------	--	-------	--------

Complexity: Inconsistent Understanding

Permissions are inconsistently classified.

- sso:PutPermissionPolicy is classified as **Permissions Management**.
- sso:PutInlinePolicyToPermissionSet is classified as **Write**.



Complexity: IAM Management & Prevention

- Permissions Classification and Taxonomy
- Allow and Monitor Strategy
- RCPs and SCPs: Set a Perimeter
- Denying Access to Actions
 - sqs:AddPermission vs sqs:SetQueueAttributes
 - ses:PutIdentityPolicy vs ses>CreateEmailIdentityPolicy

Conclusion

- Duplicate Permissions do exist in AWS.
- Defining IAM Strategy: Deny, Allow but Monitor, Allow.
- Detection and Prevention: Work with your Security Tooling.
- Strategy: Purpose-Driven IAM Configuration & Understanding Nuances.

Future & Contact

- Future Research and Tooling for Duplicate Permissions.
- More to come for AWS IAM and Data Perimeters. Reach out if you're interested!
- Email: jason@fogsecurity.io



Jason Kao
Cloud Data Security

